

CÓMO CREAR UN PROGRAMA DE CENTRO DE OPERACIONES DE SEGURIDAD

Manual práctico y conciso de implementación

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

Propósito

Use este manual para trabajo legal, autorizado y defensivo. Adapte los controles al riesgo, las obligaciones legales, la accesibilidad y los recursos disponibles.

Propósito y modelo operativo

- Defina misión, alcance, clientes, autoridad, horario, escalamiento y relación con respuesta a incidentes.
- Seleccione un modelo interno, externo, compartido o virtual según riesgo, personal, cobertura y presupuesto.
- Cree un catálogo de monitoreo, triage, investigación, hunting, ingeniería de detección, vulnerabilidades e informes.

Personas y funciones

- Asigne gerente, líderes de turno, analistas, ingenieros de detección, hunters, respondedores, ingenieros de plataforma y enlaces empresariales.
- Use niveles claros sin limitar el desarrollo profesional.
- Ofrezca capacitación, mentoría, procedimientos accesibles, cargas razonables y controles de fatiga.

Tecnología y telemetría

- Priorice identidad, endpoints, red, nube, correo, aplicaciones, vulnerabilidades y servicios críticos.
- Normalice tiempo, activos, usuarios y campos.
- Proteja registros, defina retención, vigile fallas de ingestión y evite recopilar datos sensibles sin propósito.

Ingeniería de detección

- Relacione detecciones con amenazas, rutas de ataque, activos e impacto.
- Documente propósito, lógica, fuentes, propietario, severidad, falsos positivos, respuesta y pruebas.
- Ajuste continuamente y retire reglas obsoletas.

Triage e investigación

- Combine confianza, alcance, privilegio, datos, impacto y explotación activa.
- Conserve evidencia y registre decisiones.
- Escale rápidamente cuando haya seguridad humana, datos sensibles, privilegios o compromiso amplio.

Hunting e inteligencia

- Use inteligencia para crear hipótesis comprobables.
- Realice hunting solamente en entornos autorizados.
- Convierta resultados validados en detecciones y controles.

Calidad, métricas y hoja de ruta

- Mida cobertura, calidad de alertas, tiempo de reconocimiento y contención, incidentes reabiertos, brechas y carga.
- No premie velocidad a costa de precisión.
- Días 1-30: alcance, telemetría, roles y playbooks. Días 31-60: ciclo de detección y ejercicios. Días 61-90: hunting, métricas, automatización y revisión ejecutiva.

Lista de implementación

- ☐ Responsable asignado
- ☐ Alcance aprobado
- ☐ Inventario completo
- ☐ Riesgos priorizados
- ☐ Políticas documentadas
- ☐ Controles implementados
- ☐ Evidencia conservada
- ☐ Excepciones con vencimiento
- ☐ Pruebas completadas
- ☐ Revisión directiva registrada

Referencias oficiales

- NIST SP 800-61 Rev. 3: <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
- NIST CSF 2.0: <https://www.nist.gov/cyberframework>
- MITRE ATT&CK: <https://attack.mitre.org/>

Licencia

Copyright © 2026 Alberto (Al) Leiva. Licencia CC BY-NC-SA 4.0.